

Déploiement d'AppLocker et Sécurisation PowerShell (CLM)

Objectifs

1. Déployer une politique de Liste Blanche (Whitelisting) via AppLocker.
2. Protéger le système contre le contournement via les dossiers permissifs (`C:\Windows\Tasks`).
3. Activer le filtrage des bibliothèques (DLL) pour contrer les malwares modernes.
4. Prouver le verrouillage automatique de PowerShell en Constrained Language Mode (CLM).

Préparation de la simulation d'attaque

Puisque nous sommes sur un Contrôleur de Domaine, nous allons créer un utilisateur standard fictif (sans aucun droit d'administration) pour simuler un attaquant ou un malware.

Ouvrez une invite de commande (CMD) en tant qu'Administrateur et créez l'utilisateur :
`net user pirate Attaque2026! /add`

1.

Créez un dossier temporaire qui simulera le point de chute du malware :
`mkdir C:\Temp`

`copy C:\Windows\System32\ping.exe C:\Temp\malware.exe`

2.

L'État des lieux (Avant AppLocker)

Vérifions qu'un utilisateur standard a, par défaut, tous les droits pour exécuter des binaires inconnus et utiliser PowerShell de manière offensive.

Ouvrez une invite PowerShell en usurpant l'identité de l'utilisateur standard :
`runas /user:formation\pirate powershell.exe`

1. (Tapez le mot de passe `Attaque2026!`. Une nouvelle fenêtre bleue s'ouvre).

Dans cette nouvelle fenêtre (en tant que **pirate**), exécutez le faux malware :
C:\Temp\malware.exe 127.0.0.1

2. Résultat : Le binaire s'exécute sans problème.

Vérifiez le mode de langage actuel de PowerShell :
\$ExecutionContext.SessionState.LanguageMode

3. Résultat : **FullLanguage**. L'attaquant a accès à toute l'API Windows et au framework .NET. (Fermez cette fenêtre).

Configuration d'AppLocker (Niveau Architecte)

2.1 Activation du service vital (AppIDSvc)

AppLocker ne bloque rien si le service d'Identité de l'application n'est pas démarré.

1. Ouvrez la console **Gestion de stratégie de groupe** (**gpmc.msc**).
2. Créez une nouvelle GPO liée à l'OU **Domain Controllers**, nommez-la **GPO-SEC-AppLocker-Tier0**, et modifiez-la.
3. Allez dans : Configuration ordinateur > Stratégies > Paramètres Windows > Paramètres de sécurité > Services système.
4. Double-cliquez sur **Identité de l'application** (Application Identity), cochez Définir ce paramètre, et mettez-le en **Automatique**.

2.2 Création des Règles (Le piège des DLL)

1. Toujours dans la GPO, descendez dans : ... Paramètres de sécurité > Stratégies de contrôle d'application > AppLocker.
2. **Activation du support des DLL :**
 - Faites un clic droit sur **AppLocker** > **Propriétés**.
 - Dans l'onglet Avancé, cochez la case **Activer la collection de règles de DLL** (Enable the DLL rule collection).
 - Dans l'onglet Application (Enforcement), cochez "Configuré" et "Appliquer les règles" pour les 3 types : **Exécutables**, **Scripts**, et **DLL**. Cliquez sur OK.
3. **Génération des règles par défaut :**
 - Clic droit sur **Règles de l'exécutable** > Créer les règles par défaut.
 - Clic droit sur **Règles de script** > Créer les règles par défaut.
 - Clic droit sur **Règles de DLL** > Créer les règles par défaut. (Ces règles autorisent tout ce qui est dans C:\Windows et C:\Program Files, et autorisent les Administrateurs à tout faire).

2.3 Contrer le Bypass ANSSI (Le dossier inscriptible)

Par défaut, `C:\Windows\Tasks` est accessible en écriture aux utilisateurs standards. Les attaquants y déposent leurs malwares pour contourner la règle par défaut d'AppLocker. Nous allons boucher cette faille.

1. Clic droit sur **Règles de l'exécutable** > **Créer une règle...**
2. Action : **Refuser** (Deny) / Utilisateur : **Tout le monde** (Everyone).
3. Condition : **Chemin d'accès** (Path).
4. Chemin : `C:\Windows\Tasks\*`
5. Nommez la règle : **DENY - Bypass Tasks Folder** et terminez.

(Fermez l'éditeur de GPO).

Application et Preuve d'Audit

3.1 Déploiement

Sur votre Contrôleur de Domaine (en Administrateur), forcez la GPO :
`gpupdate /force`

Démarrez manuellement le service pour ne pas avoir à redémarrer le serveur :
`Start-Service AppIDSvc`

3.2 L'Audit (La vue de l'attaquant)

Relançons notre simulation d'attaque pour observer les défenses en action.

Ouvrez à nouveau une session PowerShell en tant que pirate :
`runas /user:formation\pirate powershell.exe`

Le blocage classique : Tentez d'exécuter le malware depuis le dossier temporaire.
`C:\Temp\malware.exe 127.0.0.1`

Accès refusé par la stratégie de groupe. AppLocker fonctionne.

Le blocage avancé (Bypass Tasks) : L'attaquant tente de ruser en copiant son malware dans le dossier permissif de Windows :

`copy C:\Temp\malware.exe C:\Windows\Tasks\`

`C:\Windows\Tasks\malware.exe 127.0.0.1`

Accès refusé ! Votre règle explicite d'interdiction "Deny" a pris le dessus sur la règle d'autorisation par défaut.

La mort du "Living off the Land" (PowerShell CLM) : AppLocker étant actif, vérifions l'état de l'interpréteur PowerShell pour cet utilisateur :

`$ExecutionContext.SessionState.LanguageMode`

ConstrainedLanguage. L'attaquant ne peut plus utiliser l'API Win32 ni le framework .NET. Le moteur PowerShell est mathématiquement neutralisé.

Traçabilité pour le SOC (Event Viewer)

Où vont les alertes lorsqu'AppLocker bloque un programme ?

1. Ouvrez l'**Observateur d'événements** (`eventvwr.msc`).
2. Naviguez dans : Journaux des applications et des services > Microsoft > Windows > AppLocker > EXE and DLL.
3. Vous constaterez des événements d'**Erreur (ID 8004)** indiquant exactement quel fichier a été bloqué et pour quel utilisateur. Ce sont ces journaux qui doivent être envoyés au SIEM (SOC).